Strong Authentication - MFA - Backup Lab: SMS OTP through a webhook

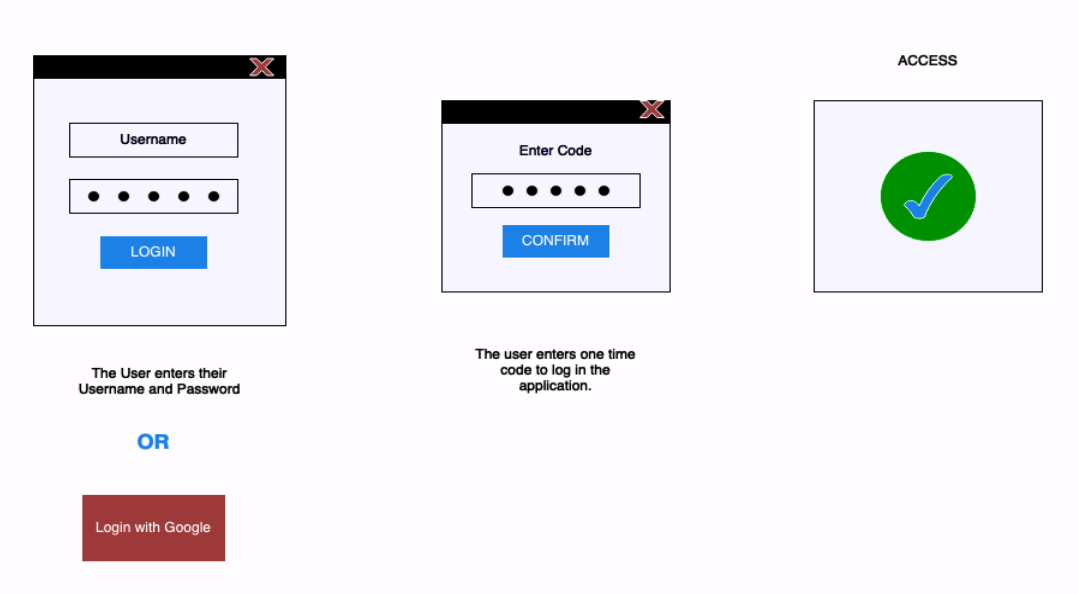
Introduction:

In the past when a user wanted to transfer money online, he had to log in to that bank's web application via his username and password. With impressive technological advancements, cyber crimes have increased as well. Hence, this username and password can be stolen by anyone. So in order to assure that the user who is attempting to log in using the username and password is actually the user, the bank's website uses Multi Factor Authentication(MFA). If this web site has been configured to perform MFA, the user who tries to log in to the web application has to give the username and password along with an additional authentication step, such as one-time password(OTP), sent to the user's mobile number. Hence, this transaction is safer than using only the username and password.



To demonstrate this scenario, we are going to log in to a sample web application called pickup-dispatch using MFA. In the first step the user has to provide their username/ password. Once he is authenticated, the user receives a one-time password to their registered mobile phone. This is a backup for the Vonage (Nexmo) version of the lab: instead of a real SMS gateway, WSO2 Identity Server posts the SMS to a webhook, and you read the OTP there. It needs no SMS account, no phone and no internet access.

CC BY 4.0



Setting up:

Start a webhook receiver (instead of Nexmo)

1. Copy `WebhookReceiver.java` from the Resources folder of this lab to any folder, for example `C:\wso2\webhook`.
2. Open a terminal (Command Prompt or PowerShell on Windows) in that folder and run it with the same JDK you use for WSO2 Identity Server (JDK 21 or 25). No compiling is needed:

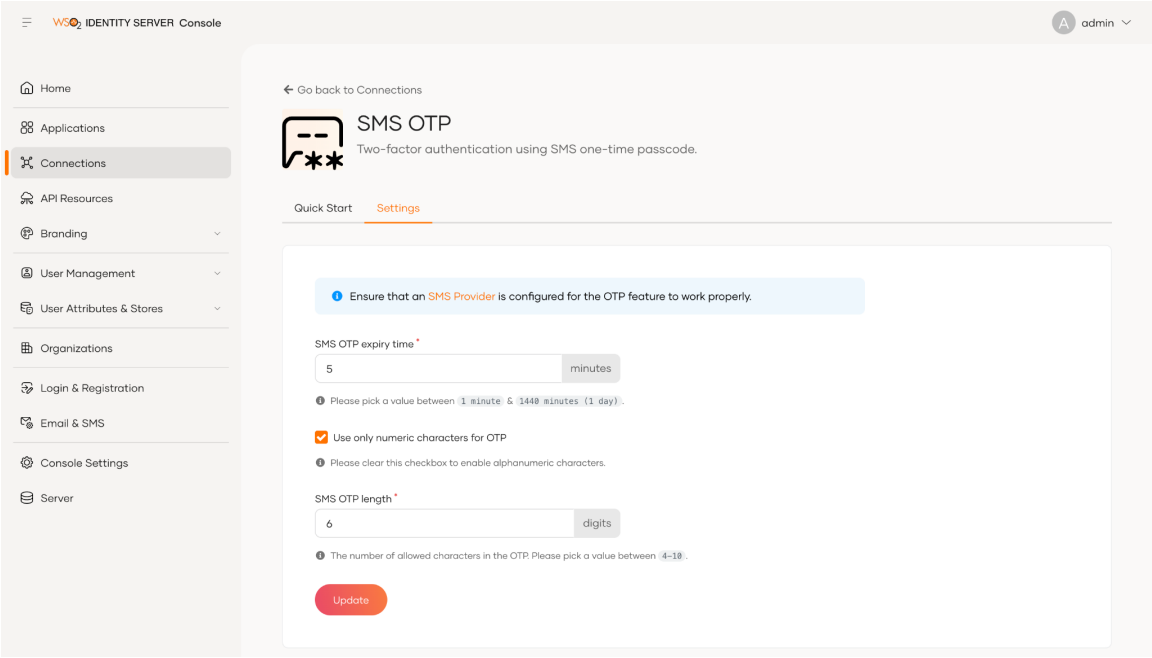
   ```
   java WebhookReceiver.java
   ```
3. It prints `Webhook receiver listening on http://localhost:8090/sms`. Keep this window open. If Windows Firewall asks about Java, you can click **Cancel**: the receiver is only called from the same machine.
4. Open `http://localhost:8090/` in a browser. The page lists every message the receiver gets and refreshes every 3 seconds.
5. If port 8090 is in use, start it on another port, for example `java WebhookReceiver.java 9090`, and use that port in the next section.

CC BY 4.0

Alternative with internet access: open https://webhook.site, copy your unique URL and use it as the SMS Provider URL below. Messages then show on the webhook.site page instead. (The local receiver is preferred because it works without internet.)

Configure SMS OTP

1. Login to the WSO2 Identity Server **Console,** using your admin credentials (e.g. admin:admin).
2. In the WSO2 Identity Server **Console,** from the menu click **Connections.**
3. Open the **SMS OTP** local authenticator listed.
4. You will be prompted to the below page.



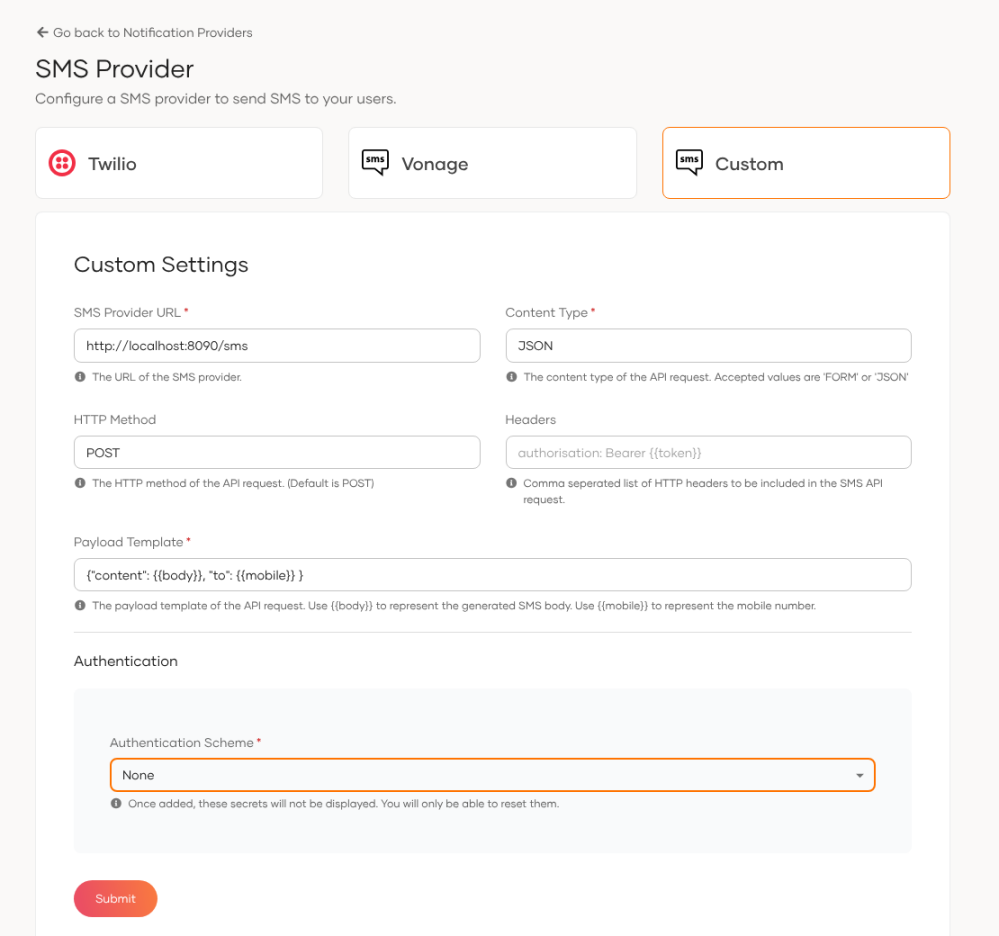
5. For the simplicity of this tutorial, let's keep the default configuration.

Create a Custom SMS provider that calls the webhook

1. In the WSO2 Identity Server Console, from the menu click **Notification Channels**.
2. Select **SMS Provider** and click the **Custom** option.

CC BY 4.0

3. Enter these values:
    a. SMS Provider URL: `http://localhost:8090/sms`
    b. Content Type: `JSON`
    c. HTTP Method: `POST`
    d. Headers: leave empty
    e. Payload Template: `{"content": {{body}}, "to": {{mobile}} }`
    f. Authentication Scheme: **None**



4. Click **Submit**. You see **Update Successful**.

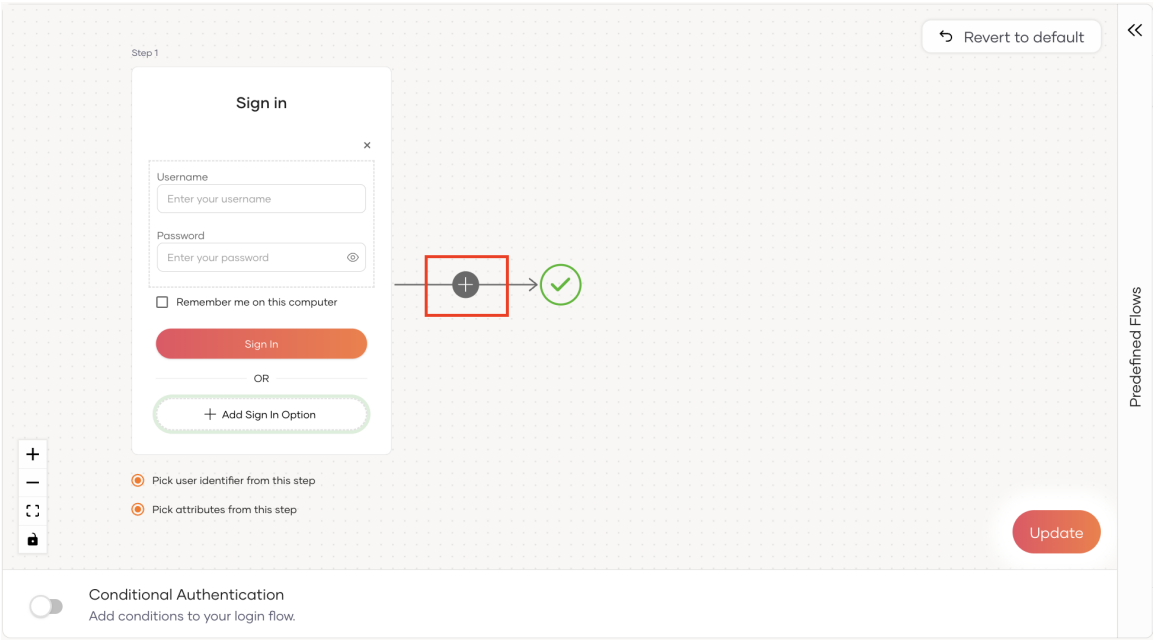
    Type the payload template exactly as shown, without quotes around `{{body}}` and `{{mobile}}`: Identity Server inserts them as quoted JSON strings.

CC BY 4.0

Configure MFA to the sample application

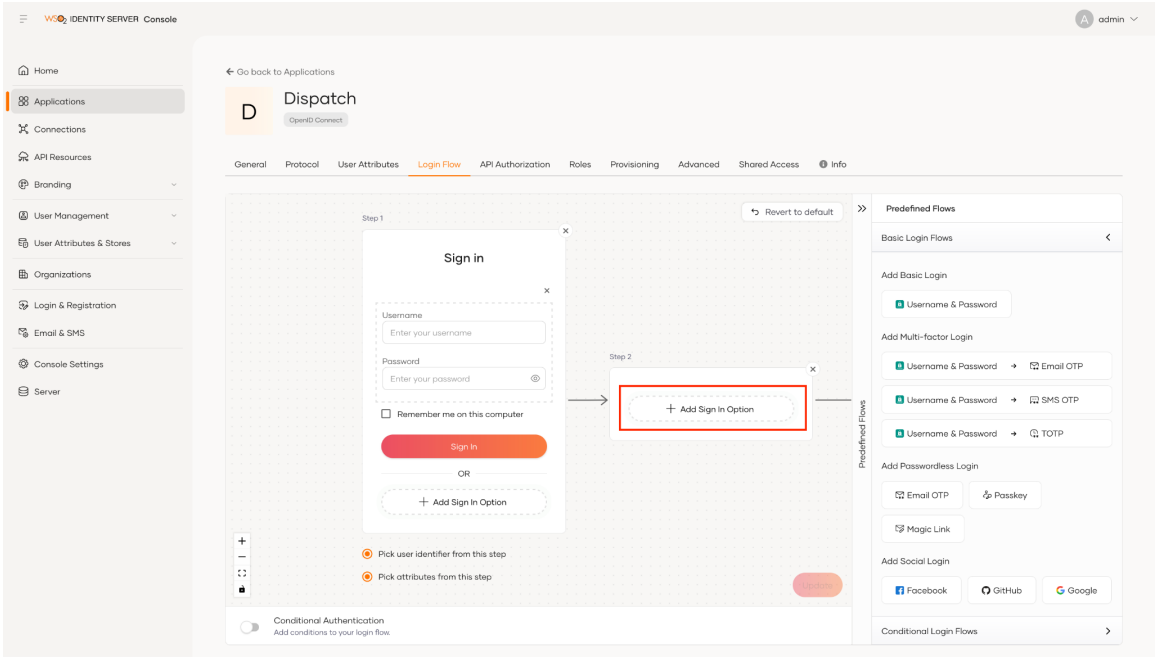
Let's SMS OTP as the 2nd factor of authentication.

1. Use the **Dispatch** Application configured in **6. Single Sign-On with OpenID Connect** Lab.
2. In the WSO2 Identity Server **Console,** from the menu click **Applications.**
3. Click on application **Dispatch.**
4. Goto the **Login Flow**.
5. Click on **Revert to default**, to remove previously configured authentication mechanisms.
6. Next select **+** icon followed by the screen.

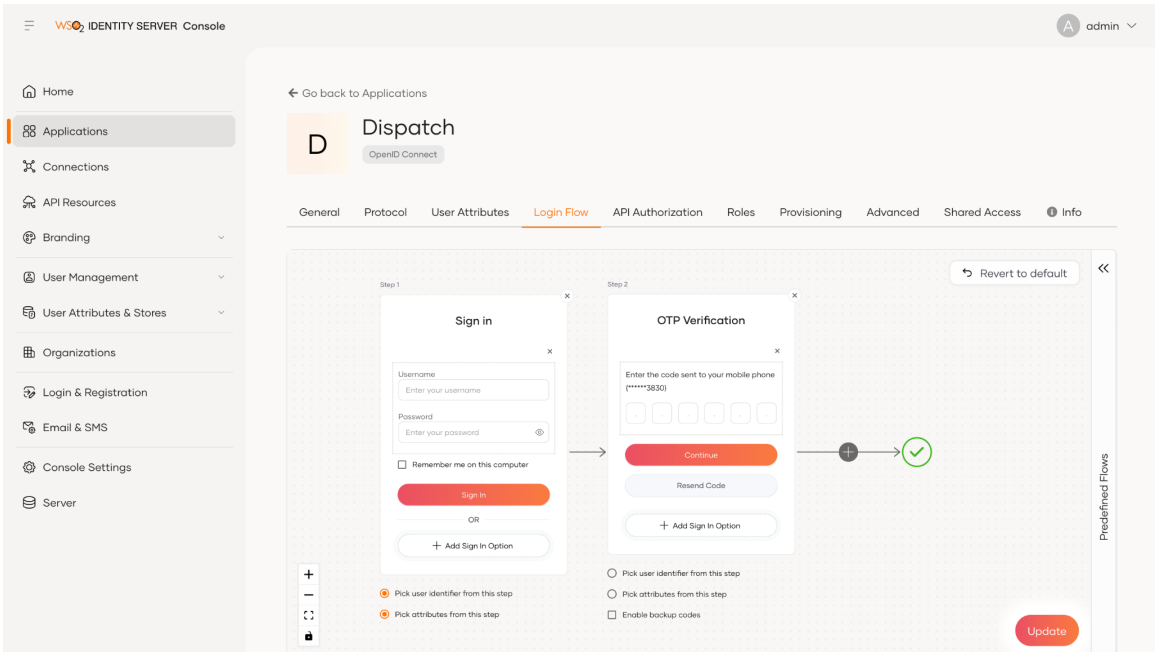


7. Click on the **+ Add Sign In Option** of the 2nd step.

CC BY 4.0



8. From the listed authentication methods, select **SMS OTP**.



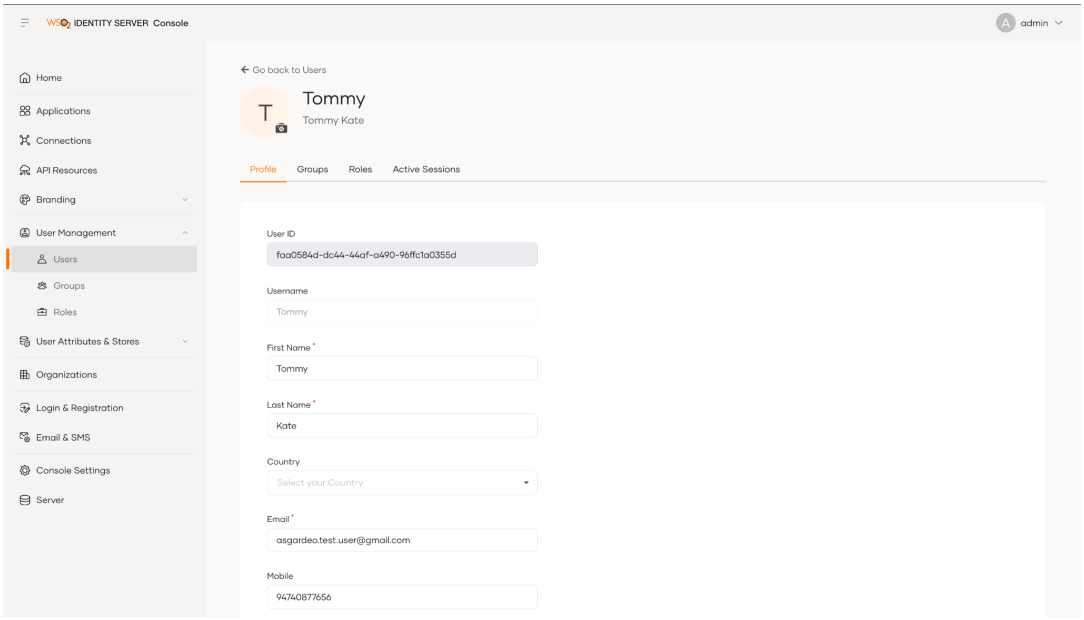
9. Click **Update**.

CC BY 4.0

Update the user

1. In the WSO2 Identity Server **Console,** from the menu click **User Management.**
2. Select User.
3. From the list of users, select the user **Tommy.**
4. Add a Mobile Number to the respective fields, for example +94771234567.

   No real SMS is sent in this lab, so any valid number works.

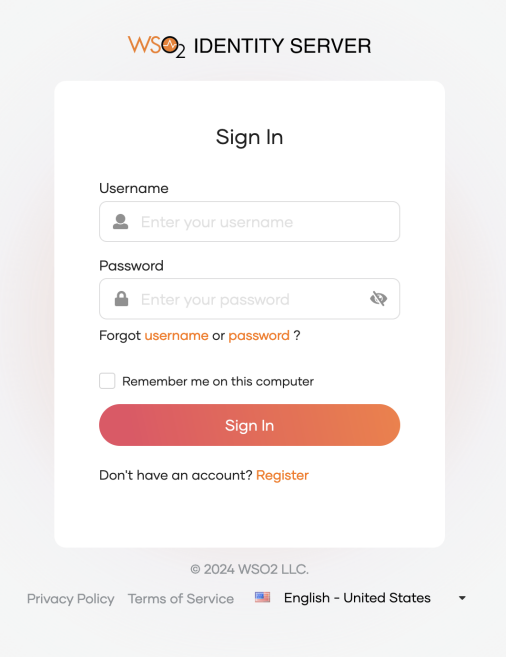


5. Click Update.

CC BY 4.0

Try It:

1. Go to http://localhost:8080/pickup-dispatch and click on the login button.
2. You will be redirected to the login page of WSO2 Identity Server. This login page consists of an option to enter the username and password. Type credentials of **Tommy**.



3. Once the above step is successful, you will be redirected to a page where you have to enter the one-time password(OTP) that has been sent to the mobile number configured in your profile.
   Switch to the webhook receiver (`http://localhost:8090/` or the terminal window). A new message shows the SMS that Identity Server sent, for example:

```
{"content": "Your one-time password for the Dispatch is 111779. This expires in 5 minutes.", "to": "+94771234567" }
```

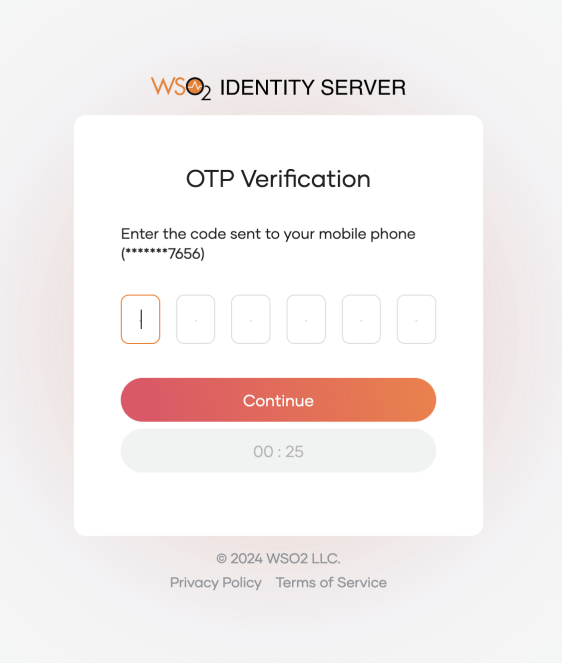
Messages received (latest first)

Possible OTP: **111779**

```
23:34:44  POST /sms
Content-type: application/json
{"content": "Your one-time password for the Dispatch is 111779. This expires in 5 minutes.", "to": "+94771234567" }
```

CC BY 4.0

Enter the 6-digit code from the message on the OTP page and click **Continue**.



4. Once you enter a valid OTP, you will be able to log in to the pickup-dispatch application. If you do not enter the OTP, you will not be able to log into the application due to an authentication failure.

CC BY 4.0